Penetration Testing Report

Engagement Overview

- **Engagement Type:** Internal Penetration Test (Post-Exploitation)
- **Target System:** Linux Server
- **Initial Access Level:** Low Privileged User (user1 via SSH)
- **Objective:** Privilege Escalation to Root
- **Testing Approach:** Black Box (Post-Access Scenario)

Executive Summary

This assessment identified critical security misconfigurations that allowed full system compromise. Starting from a low-privileged SSH user (user1), it was possible to escalate privileges to another user (user2) due to improper sudo configurations.

Further exploitation revealed that sensitive SSH private keys belonging to the root user were accessible, ultimately allowing complete administrative (root) access to the system.

Further exploitation revealed that sensitive SSH private keys belonging to the root user were accessible, ultimately allowing complete administrative (root) access to the system.

Scope of Assessment

Asset	Access Level
Linux Target System	SSH Access (user1)

Methodology

The assessment followed standard penetration testing phases:

1. Initial Access Validation

2. Privilege Enumeration
3. Lateral Movement / Privilege Escalation
4. Credential Harvesting
5. Full System Compromise

Detailed Findings

Finding 1: Misconfigured Sudo Privileges

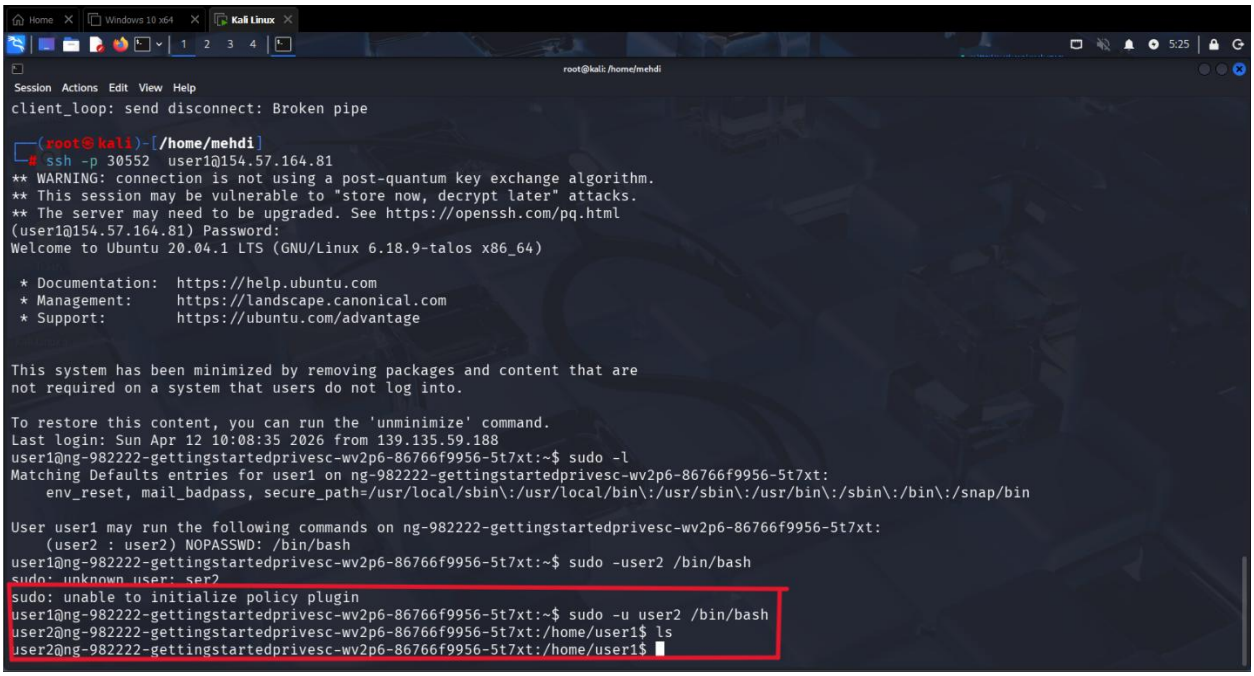
- **Severity:** Critical
- **Category:** Improper Privilege Management

Description

The user **user1** was allowed to execute /bin/bash as **user2** without requiring a password.

This configuration effectively grants immediate shell access to another user, bypassing authentication controls.

Evidence



Impact

- Unauthorized privilege escalation
- Lateral movement between users
- Increased attack surface for further exploitation

Finding 2: Exposure of Root SSH Private Key

- **Severity:** Critical
- **Category:** Sensitive Data Exposure

Description

While operating as **user2**, the root user's private SSH key was readable.

This represents a severe misconfiguration, as private keys must never be accessible to non-root users.

Evidence

cat /root/.ssh/id_rsa

Impact

- Complete compromise of root account
- Persistent unauthorized access
- Ability to bypass authentication mechanisms

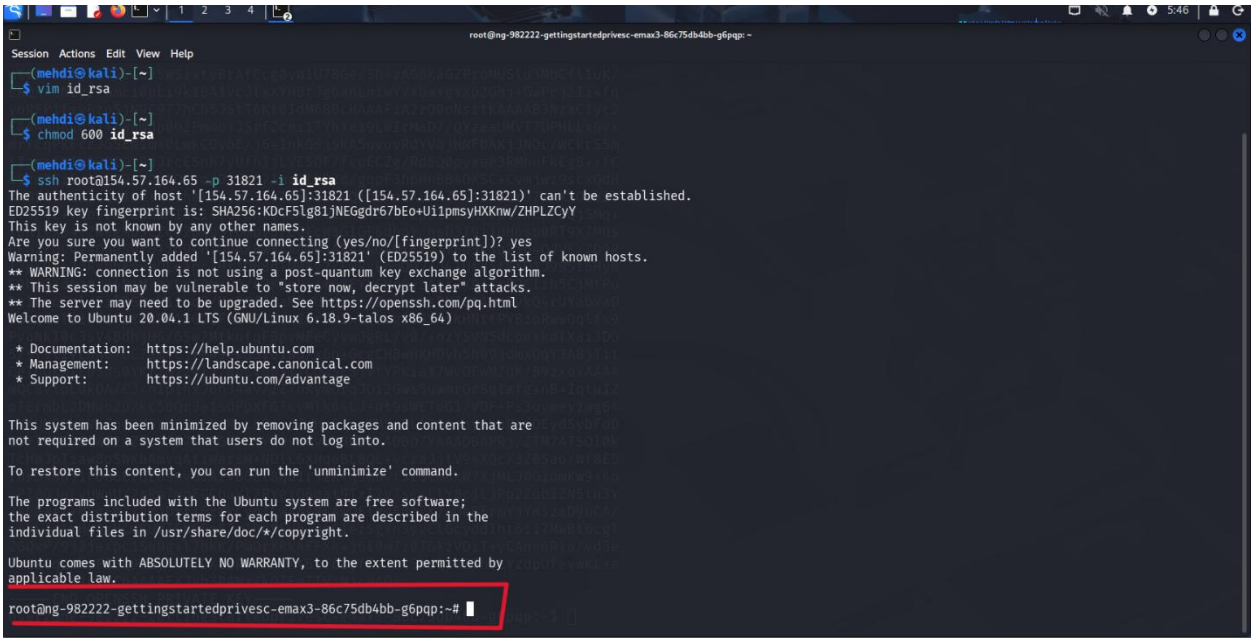
Finding 3: Full Root Compromise via SSH Key Abuse

- **Severity:** Critical
- **Category:** Privilege Escalation

Description

The exposed private key was used to authenticate as the root user from an external system.

Evidence



Impact

- Full administrative control over system
- Data exfiltration, persistence, and system manipulation possible

Attack Chain Summary

1. SSH access obtained as **user1**
2. Enumerated sudo privileges
3. Escalated to **user2** via misconfiguration
4. Extracted root private SSH key
5. Used key to gain **root access**

Risk Rating Summary

Finding	Severity
Sudo Misconfiguration	Critical
Root Key Exposure	Critical
Root Access Achieved	Critical

Recommendations

1. **Sudo Configuration Hardening**
    - Remove unnecessary sudo permissions
    - Avoid allowing shell execution (/bin/bash) via sudo
    - Enforce password requirement for privilege escalation

2. **Secure SSH Key Management**
    - Restrict access to /root/.ssh/
    - Ensure permissions:

      chmod 700 /root/.ssh

      chmod 600 /root/.ssh/id_rsa
    - Never expose private keys to non-root users

3. **Principle of Least Privilege**
    - Users should only have minimum required access
    - Regular audits of user permissions must be conducted

4. **Monitoring & Logging**
    - Enable logging for sudo usage
    - Monitor unauthorized privilege escalation attempts

Conclusion

The system is critically vulnerable due to improper privilege management and insecure handling of sensitive credentials. These issues allowed a complete compromise from a low-privileged user to root access.

Immediate remediation is required to prevent potential real-world exploitation.